

Timothy Bates

CIS5396 Project

11/24/2024

Penetration Testing Report

In alignment with the NIST Cybersecurity Framework, penetration testing of an IT infrastructure and identifying potential attack vectors that could be used for exploitation by threat agents is a critical aspect of the **Governance (GV)** category. Specifically, this aligns with control **GV.OC-01**, which focuses on understanding how cybersecurity risks can disrupt an organization's ability to achieve its business objectives. Ultimately all organizations are going to have a varied architecture that can contain vulnerabilities. These vulnerabilities can be externally facing, stemming from assets that have some kind of connection to the internet, or internally facing that a hacker would need to be inside the network already to exploit. By identifying vulnerabilities, through analyzing flaws in documentation and source code, and mapping the attack surface, businesses can proactively address these risks that may compromise the confidentiality, integrity, or availability of their infrastructure. Such disruptions could lead to operational downtime, sensitive data breaches, and financial loss, which directly disrupts any organization's business directive.

Identifying flaws in documentation is accomplished through the analysis of the configuration, operational, and technical documents that are related to an organization's infrastructure. This is part of the discovery process as the goal is to uncover potential vulnerabilities in the relationship between assets and configurations that may not be easy to uncover through simple technical testing alone. Some potential flaws that could be uncovered by penetration testers includes misconfigurations, such as weak authentication or improper firewall rules, unpatched systems that may be without the latest security updates, and insecure practices such as shared credentials or a lack of standard encryption protocols.

Source code analysis is a process that reviews the codebases of services, systems, and applications within an organization's IT infrastructure. This is to try to uncover potential vulnerabilities that stem from the source code that could be exploited by attackers. These flaws may not be detectable through other steps therefore comprehensive review of the source code is critical, either through static analysis which can be automated or manual line by line code review. Some common vulnerabilities are injection flaws (SQL, XML), lack of proper credential storing (generally hard coded), or dependency vulnerabilities from deprecated third-party libraries.

All these aspects can lead to flaws in an organization's attack surface, these flaws are vulnerabilities that threat actors could exploit to leverage cyberattacks and disrupt business operations or expose sensitive data. Understanding these flaws allows cybersecurity professionals to discern the flaws in a system and use that information to harden the network and improve the security posture of the organization.

Ifconfig to determine ip range of subnet

```
Shell No. 1
File Actions Edit View Help
#####
# WAVE 5 ##### SCORE 31337 ##### HIGH FFFFFFFF #
#####
https://metasploit.com

nitrdm
=[ metasploit v6.3.55-dev ]
+ -- --=[ 2397 exploits - 1235 auxiliary - 422 post ]
+ -- --=[ 1391 payloads - 46 encoders - 11 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > ifconfig
[*] exec: ifconfig

eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 143.88.2.22 netmask 255.255.255.0 broadcast 143.88.2.255
    inet6 fe80::250:56ff:fea8:8319 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:a8:83:19 txqueuelen 1000 (Ethernet)
    RX packets 4767142 bytes 410337575 (391.3 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 4703421 bytes 398830546 (380.3 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 22497672 bytes 6254025917 (5.8 GiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 22497672 bytes 6254025917 (5.8 GiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

msf6 > 
```

Nmap scans to enumerate the attack surface of the subnet

nmap 143.88.2.0/24 -sV to identify versions of services running on open ports

nmap 143.88.2.0/24 -A a fuller profile view of each host to help analyze complex vulnerabilities

sudo nmap 143.88.2.0/24 -O for OS detection

```
Shell No. 1
File Actions Edit View Help
msf6 > nmap 143.88.2.0/24 -sV
[*] exec: nmap 143.88.2.0/24 -sV

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-24 16:13 CST
Stats: 0:01:15 elapsed; 252 hosts completed (4 up), 4 undergoing Service Scan
Service scan Timing: About 82.76% done; ETC: 16:15 (0:00:12 remaining)
Nmap scan report for pfSense.home.arpa (143.88.2.1)
Host is up (0.00076s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
53/tcp    open  domain   Unbound
80/tcp    open  http     nginx
443/tcp   open  ssl/http nginx

Nmap scan report for 143.88.2.19
Host is up (0.00074s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2
.0)
80/tcp    open  http     Apache httpd 2.4.7
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp      CUPS 1.7
3000/tcp  closed ppp
3306/tcp  open  mysql    MySQL (unauthorized)
8080/tcp  open  http     Jetty 8.1.7.v20120910
8181/tcp  closed intermapper

Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:li
nux:linux_kernel

Nmap scan report for 143.88.2.22
Host is up (0.000017s latency).
All 1000 scanned ports on 143.88.2.22 are in ignored states.
Not shown: 1000 closed tcp ports (conn-refused)

Nmap scan report for 143.88.2.23
Host is up (0.00025s latency).
Not shown: 981 closed tcp ports (conn-refused)
PORT      STATE SERVICE  VERSION
21/tcp    open  ftp      Microsoft ftpd
80/tcp    open  http     Microsoft IIS httpd 7.5
135/tcp   open  msrpc    Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-d
s
3306/tcp  open  mysql    MySQL 5.5.20-log
3389/tcp  open  ssl/ms-wbt-server?
3920/tcp  open  ssl/exasoftport1?
4848/tcp  open  ssl/http  Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.
8)
7676/tcp  open  java-message-service Java Message Service 301
8080/tcp  open  http     Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.
8)
8181/tcp  open  ssl/http  Oracle GlassFish 4.0 (Servlet 3.1; JSP 2.3; Java 1.
8)
8383/tcp  open  http     Apache httpd
9200/tcp  open  wap-wsp?
49152/tcp open  msrpc    Microsoft Windows RPC
49153/tcp open  msrpc    Microsoft Windows RPC
49154/tcp open  msrpc    Microsoft Windows RPC
49157/tcp open  java-rmi  Java RMI
49158/tcp open  tcpwrapped

1 service unrecognized despite returning data. If you know the service/version, please s
ubmit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port9200-TCP:V=7.94SVN%I=7%D=11/24%Time=6743A538%P=x86_64-pc-linux-gnu%
SF:r(GetRequest,190,"HTTP/1.0\x20200\x200K\r\nContent-Type:\x20applicatio
```



```
Shell No. 1
File Actions Edit View Help

Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-24 16:18 CST
Nmap scan report for pfSense.home.arpa (143.88.2.1)
Host is up (0.00081s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain Unbound
80/tcp    open  http   nginx
|_ http-title: Did not follow redirect to https://pfSense.home.arpa/
443/tcp   open  ssl/http nginx
|_ tls-alpn:
|   h2
|   http/1.1
|   http/1.0
|_ http/0.9
|_ http-title: pfSense - Login
|_ ssl-cert: Subject: commonName=pfSense-65bec43e0cdee/organizationName=pfSense GUI default Self-Signed Certificate
| Subject Alternative Name: DNS:pfSense-65bec43e0cdee
|_ Not valid before: 2024-02-03T22:54:54
|_ Not valid after: 2025-03-07T22:54:54
|_ ssl-date: TLS randomness does not represent time

Nmap scan report for 143.88.2.19
Host is up (0.00065s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp     ProFTPD 1.3.5
22/tcp    open  ssh     OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 e4:0b:6c:8d:52:4c:8a:36:ff:34:3f:d6:4a:5a:7d:79 (DSA)
|   2048 0a:82:23:1c:77:63:d5:40:9f:1b:03:d9:18:2c:a8:1a (RSA)
|   256 87:2c:4f:59:dc:7e:4b:e5:55:6c:ae:cc:bc:45:2a:bd (ECDSA)
|_ 256 61:80:79:66:dc:00:7f:4d:05:4f:14:dd:d5:4b:f5:ce (ED25519)
80/tcp    open  http    Apache httpd 2.4.7
|_ http-ls: Volume /
|_ SIZE TIME FILENAME
|_ - 2021-09-16 14:31 chat/
|_ - 2011-07-27 20:17 drupal/
|_ 1.8K 2021-09-16 14:31 payroll_app.php
|_ - 2013-04-08 12:06 phpmyadmin/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp       CUPS 1.7
|_ http-methods:
|_ Potentially risky methods: PUT
|_ http-title: Home - CUPS 1.7.2
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: CUPS/1.7 IPP/2.1
3000/tcp  closed ppp
3306/tcp  open  mysql     MySQL (unauthorized)
8080/tcp  open  http      Jetty 8.1.7.v20120910
|_ http-title: Error 404 - Not Found
|_ http-server-header: Jetty(8.1.7.v20120910)
8181/tcp  closed intermapper
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time:
|_ date: 2024-11-24T22:20:43
|_ start_date: N/A
|_ clock-skew: mean: 23s, deviation: 3s, median: 21s
|_ smb2-security-mode:
|_ 3:1:1:
|_ Message signing enabled but not required
```

```
Shell No. 1
File Actions Edit View Help
msf6 > sudo nmap 143.88.2.0/24 -O
[*] exec: sudo nmap 143.88.2.0/24 -O

[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-24 16:23 CST
Nmap scan report for pfSense.home.arpa (143.88.2.1)
Host is up (0.00062s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
MAC Address: 00:50:56:A8:52:9D (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): FreeBSD 11.X (95%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (95%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 143.88.2.19
Host is up (0.00058s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp   open  microsoft-ds
631/tcp   open  ipp
3000/tcp  closed ppp
3306/tcp  open  mysql
8080/tcp  open  http-proxy
8181/tcp  closed intermapper
MAC Address: 00:50:56:A8:70:F9 (VMware)
Aggressive OS guesses: Linux 3.2 - 4.9 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 (94%), Linux 3.13 - 3.16 (94%), OpenW
rt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1
(Linux 3.4) (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%), Linux 4.5 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

Nmap scan report for 143.88.2.23
Host is up (0.00035s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
3389/tcp  open  ms-wbt-server
3920/tcp  open  exasoftport1
4848/tcp  open  appserv-http
7676/tcp  open  imqbrokerd
8080/tcp  open  http-proxy
8181/tcp  open  intermapper
8383/tcp  open  m2mservices
9200/tcp  open  wap-wsp
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
MAC Address: 00:50:56:A8:66:37 (VMware)
Device type: general purpose
Running: Microsoft Windows 7|2008|8.1
OS CPE: cpe:/o:microsoft:windows_7:- cpe:/o:microsoft:windows_7::sp1 cpe:/o:microsoft:windows_server_2008::sp1 cpe:/o:
microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows 7 SP0 - SP1, Windows Server 2008 SP1, Windows Server 2008 R2, Windows 8, or Windows 8.1 U
```

Four open hosts determined with determined information to try to spot vulnerabilities

143.88.2.1

Host is up but OS scan was indeterminate, port 80 is open with http which is unsecure due to lack of encrypted traffic

```
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-24 16:23 CST
Nmap scan report for pfSense.home.arpa (143.88.2.1)
Host is up (0.00062s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
MAC Address: 00:50:56:A8:52:9D (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): FreeBSD 11.X (95%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (95%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```

143.88.2.19

Running Linux OS, TCP Ports 21,22,80 are open and using unencrypted protocols that transfer data in plaintext

```
Nmap scan report for 143.88.2.19
Host is up (0.00058s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp   open  microsoft-ds
631/tcp   open  ipp
3000/tcp  closed ppp
3306/tcp  open  mysql
8080/tcp  open  http-proxy
8181/tcp  closed intermapper
MAC Address: 00:50:56:A8:70:F9 (VMware)
Aggressive OS guesses: Linux 3.2 - 4.9 (98%), Linux 3.10 - 4.11 (94%), Linux 3.13 (94%), Linux 3.13 - 3.16 (94%), OpenWrt Chaos Calmer 15.05 (Linux 3.18) or Designated Driver (Linux 4.1 or 4.4) (94%), Linux 4.10 (94%), Android 5.0 - 6.0.1 (Linux 3.4) (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.16 (94%), Linux 4.5 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
```


143.88.2.22

Host is up but all ports are in ignored status and os details not determined

```
Nmap scan report for 143.88.2.22
Host is up (0.000038s latency).
All 1000 scanned ports on 143.88.2.22 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops
```

143.88.2.23

Most likely running Windows 7/8/8.1 operating system. Older OS with possible vulnerabilities. Also has an open HTTP that is handling unencrypted web data

```
Nmap scan report for 143.88.2.23
Host is up (0.00035s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
3389/tcp  open  ms-wbt-server
3920/tcp  open  exasoftport1
4848/tcp  open  appserv-http
7676/tcp  open  imqbrokerd
8080/tcp  open  http-proxy
8181/tcp  open  intermapper
8383/tcp  open  m2mservices
9200/tcp  open  wap-wsp
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
MAC Address: 00:50:56:A8:66:37 (VMware)
Device type: general purpose
Running: Microsoft Windows 7|2008|8.1
OS CPE: cpe:/o:microsoft:windows_7::- cpe:/o:microsoft:windows_7::sp1 cpe:/o:microsoft:windows_server_2008::sp1 cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows 7 SP0 - SP1, Windows Server 2008 SP1, Windows Server 2008 R2, Windows 8, or Windows 8.1 Update 1
Network Distance: 1 hop
```